Plan de Pruebas y Evidencias

Pruebas unitarias, de integración, funcionales, de rendimiento y de seguridad

Estrategia, casos de prueba, criterios de aceptación y registro de evidencias del módulo administrativo y de la tienda en línea, por sprint.

Proyecto	FarmaClick - Sistema de gestión para farmacias - Módulo administrativo
Cliente / contraparte	MediFarm
Equipo	D-Software: Alejandro Fuentes Navarrete, Víctor Rubilar Inostroza, Robert González Muñoz
Asignatura	PTY4614 - Capstone
Metodología	Scrum (sprints de 2 semanas)
Código del documento	DOC-08
Versión	1.3
Fecha	21 de octubre de 2026
Repositorio	https://github.com/Alefuentes982/FarmaClick

Control de versiones

Versión	Fecha	Autor	Cambios
1.0	15-10-2026	Alejandro Fuentes (PO)	Creación de plan de pruebas y primeras ejecuciones.
1.1	17-10-2026	Víctor Rubilar (SM)	Ejecución de pruebas, adjunta evidencias.
1.2	21-10-2026	Alejandro Fuentes (PO)	Resultados de las pruebas de integración, seguridad y rendimiento con sus evidencias; CP-INT-09 aprobado con las evidencias de Víctor Rubilar (17-10-2026); anexos A (técnico) y B (funcional) de evidencias.
1.3	21-10-2026	Alejandro Fuentes (PO)	Las ejecuciones del 17 al 21-10 quedan registradas en el Sprint 5 como línea base de HU-56, HU-57 y HU-58, que se cierran al repetirlas con la tienda. Resumen por sprint corregido.

Contenido

Contenido

1. Objetivo y alcance 3
2. Estrategia 3
2.1 Entornos 3
2.2 Criterios de entrada y salida 4
2.3 Gestión de defectos 4
3. Pruebas unitarias (automatizadas) 4
4. Pruebas de integración 6
4.1 Base de datos (automatizada) 6
4.2 API de punta a punta 7
5. Pruebas funcionales y de aceptación 8
5.1 Plan de pruebas de la caja (HU-55) 10
5.2 Casos de la tienda en línea (Sprints 5 a 7, pendientes al 21-10-2026) 11
6. Pruebas de rendimiento (HU-57) 12
7. Pruebas de seguridad (HU-58) 13
8. Evidencias 15
9. Resumen por sprint 15

1. Objetivo y alcance

Verificar que el módulo administrativo cumple los criterios de aceptación de las historias de usuario y los requisitos no funcionales antes de pasar cada incremento a producción. En este documento se cubren los once módulos del backend, las pantallas del frontend, la base de datos y la infraestructura de despliegue. Desde el Sprint 5 incorpora la **tienda en línea** (casos CP-WEB) y en el Sprint 8 las pruebas de aceptación con MediFarm.

2. Estrategia

Nivel	Qué verifica	Herramienta	Cuándo	Responsable
Unitarias	Reglas de negocio y validaciones (redondeo, reembolsos, cobros, RUT, esquemas zod, informes, PDF/Excel/CSV)	node:test (61 pruebas)	Cada push y Pull Request (job backend de la CI)	Desarrollador de la historia
Integración - base de datos	Esquema completo y migraciones 001-010 sobre PostgreSQL 16 limpio; idempotencia	Job esquema de la CI	Cada push y Pull Request	Automático
Integración - API	Flujos HTTP de punta a punta con base real (login, permisos, consultas)	scripts/humo_y_seguridad.sh (curl)	Antes de cada Sprint Review y tras cada despliegue	Robert (QA)
Funcionales / aceptación	Criterios de aceptación de cada historia en el entorno dev	Casos CP-* de este documento	Durante el sprint; aceptación en la Review	Robert + PO
Rendimiento	Tiempo de respuesta y errores con 20 usuarios concurrentes	k6 (scripts/carga_k6.js)	Línea base en el Sprint 5 (20-10); HU-57 se cierra en el Sprint 8 con la tienda	Robert
Seguridad	Autenticación, autorización, entradas maliciosas, cabeceras, RLS, secretos, dependencias	humo_y_seguridad.sh, OWASP ZAP, npm audit, seguridad_rls.sql, job seguridad	Línea base en el Sprint 5 (20 y 21-10); HU-58 se cierra en el Sprint 7; job seguridad en cada push	Robert + Alejandro
De punta a punta - tienda	Compra completa: catálogo > carrito > checkout > Webpay Plus > retiro o despacho	Casos CP-WEB, tarjetas de prueba de Transbank	Sprint 7 (HU-82)	Robert
Aceptación del cliente (UAT)	Guion por épica ejecutado con usuarios de MediFarm; acta de aceptación	Guion de aceptación	Sprint 8 (HU-83)	Robert + PO + MediFarm

2.1 Entornos

Entorno	Dirección	Datos	Uso en pruebas
Local	http://localhost:5173 - API :3000	PostgreSQL en Docker con 90 productos de prueba	Desarrollo, pruebas unitarias e integración
CI (GitHub Actions)	Ejecutores de GitHub	PostgreSQL 16 de servicio, vacío	Unitarias, esquema, build
Dev / staging	http://155.181.171.118/	Supabase farmaclick-dev (datos de prueba)	Funcionales, aceptación, caja, seguridad
Producción	https://farmaclick-medifarm.duckdns.org	Supabase farmaclick-prod	Prueba de humo tras cada despliegue; rendimiento en horario sin uso

2.2 Criterios de entrada y salida

- **Entrada:** la historia cumple la Definition of Ready; el código está en develop y la CI quedó en verde; el despliegue en dev terminó bien.
- **Salida (por historia):** todos sus casos aprobados o con defectos de severidad baja aceptados por el PO; evidencia registrada.
- **Salida (para producción):** 0 defectos críticos o altos abiertos; prueba de humo en producción aprobada; migraciones aplicadas en Supabase prod.

2.3 Gestión de defectos

Severidad	Definición	Tiempo de respuesta
Crítica	Pérdida o corrupción de datos, caja descuadrada, sistema caído	Mismo día; bloquea el paso a producción
Alta	Funcionalidad principal no disponible sin alternativa	Dentro del sprint
Media	Falla con alternativa disponible	Sprint siguiente
Baja	Estética, textos	Según prioridad del PO

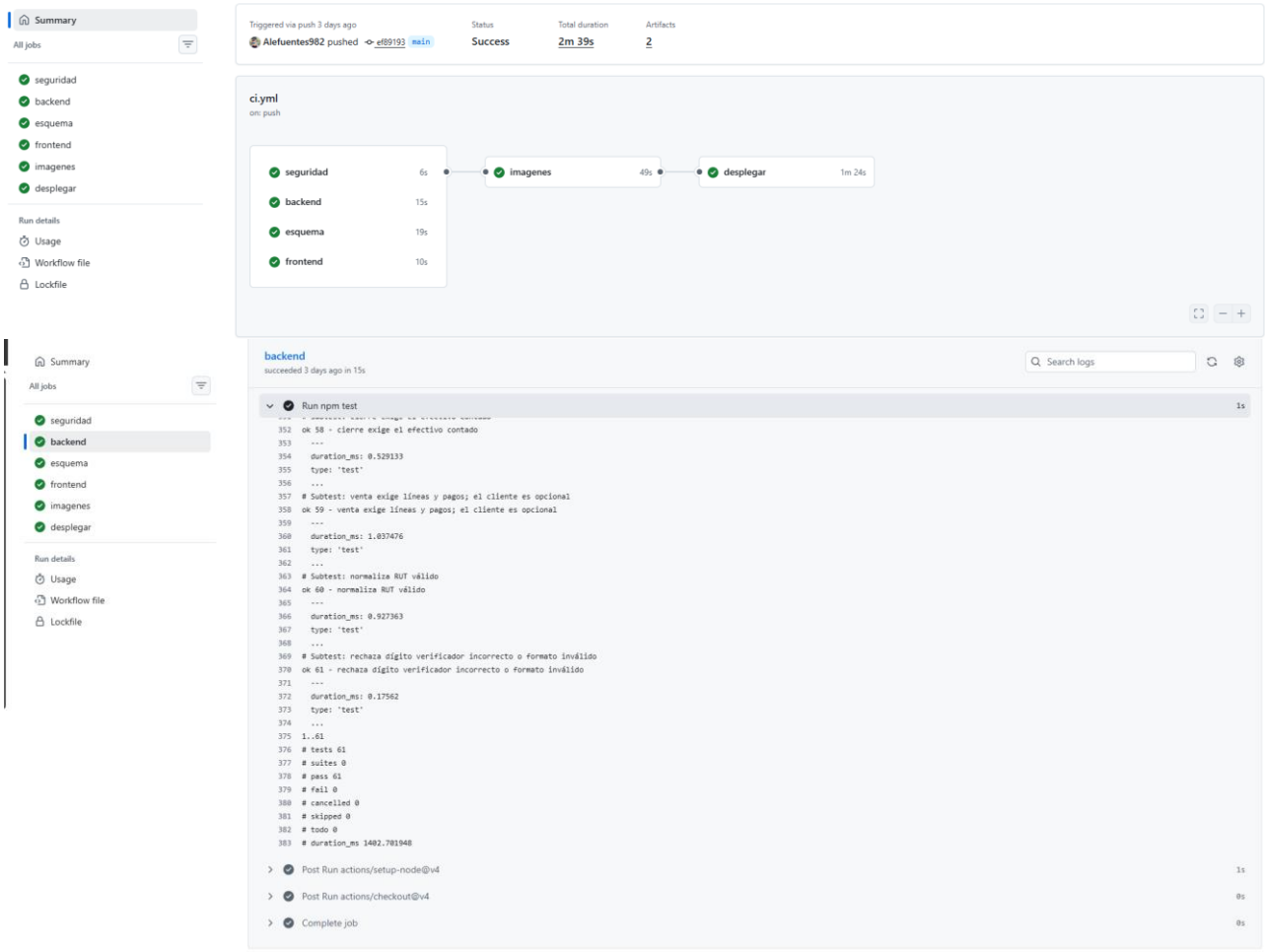
Los defectos se registran como tarjetas en Trello con la etiqueta **Bug**, la severidad, los pasos para reproducir y la captura. Se cierran cuando la corrección se despliega y se vuelve a probar.

3. Pruebas unitarias (automatizadas)

Se ejecutan con el ejecutor nativo de Node (`node --test`) en cada push y Pull Request (job **backend** de `ci.yml`) y localmente con *`docker compose exec api npm test`*. Hoy son **61 pruebas en 16 archivos**, todas aprobadas. **Evidencia:** UNIT-01_20261017.png (61 de 61 aprobadas en 2,78 s en la réplica local de la rama dev, 17-10-2026) y CI_backend_20261020.png (ejecución n.º 18 de la CI).

Archivo	N.º	Qué verifica
core/correo.test.js	3	• correoSchema normaliza y valida la dirección • sin SMTP_HOST el envío responde 503 con un mensaje claro • el cuerpo del correo menciona el documento y escapa el HTML
core/documentos.test.js	1	formatoNumero rellena con ceros
core/excel.test.js	3	• la hoja trae título, contexto, encabezado, filas con formato y totales con fórmula • sin filas no hay fila de totales ni filtro; el nombre de la hoja se limita a 31 caracteres • la ficha escribe pares etiqueta/valor con su tipo
core/fechas.test.js	2	• rangoFechas acepta vacíos y rangos válidos • rangoFechas rechaza formato inválido y rango invertido
core/redondeo.test.js	3	• Ley 20.956: terminaciones 1 a 4 bajan y 5 a 9 suben al múltiplo de $10 • el ajuste es negativo si se cobra de menos y positivo si se cobra de más • los cálculos en centavos no arrastran errores de coma flotante
core/sql.test.js	4	• likeParam escapa comodines y devuelve null si no hay texto • paging limita y calcula el desplazamiento • buildUpdate arma el UPDATE con las claves recibidas • listResponse separa el total de las filas
modules/cuadratura/avisos.test.js	1	los recordatorios salen 60 y 30 minutos antes de las 23:59, una sola vez cada uno
modules/cuadratura/esquemas.test.js	3	• la corrección exige campo válido, monto no negativo y motivo de al menos 10 caracteres • la observación no puede ir vacía • el cierre por fuerza mayor exige monto y motivo; el arqueo, solo el monto
modules/cuadratura/servicio.test.js	4	• esSupervisor depende del permiso de supervisión de caja, no del de usuarios • un cajero solo consulta sus propios turnos aunque pida otros

Archivo	N.º	Qué verifica
		• un administrador puede filtrar por cajero, sucursal y estado • la revisión con observaciones exige explicación
modules/dashboard/dashboard.test.js	7	• el catálogo tiene ids únicos y columnas bien definidas • cada consulta recibe los parámetros que usa • los informes de inventario y compras exigen su permiso además del dashboard • ejecutarInforme convierte números, aplica la fila y suma las columnas marcadas • CSV: separador ;, comillas, BOM y sin fórmulas ejecutables • formatos del PDF y anchos de columna • el PDF y el CSV se entregan como JSON con base64
modules/devoluciones/esquemas.test.js	2	• los filtros vacíos se ignoran y los montos llegan como número • rechaza montos negativos, rangos invertidos e identificadores inválidos
modules/devoluciones/servicio.test.js	9	• codigoDevolucion da formato DEV-000123 • el reembolso en partes suma exactamente el subtotal de la línea • distribuirReembolso reparte por medio en orden y sin exceder el saldo • cotizarDevolucion calcula por línea y rechaza más de lo disponible • esquemas: el stock no se reingresa por defecto y el motivo es obligatorio • el efectivo se sugiere redondeado y el resto de la devolución va por tarjeta • el efectivo devuelto nunca pasa de lo disponible en efectivo • validarReembolso calcula el redondeo y exige el efectivo redondeado • validarReembolso: sin efectivo calza exacto; con tope disponible se respeta
modules/inventario/ajustes.test.js	4	• ajuste positivo acepta lote existente o lote nuevo • ajuste positivo exige lote y no admite ambos • merma y ajuste negativo exigen lote existente y no pueden crear uno • la observación es obligatoria y la cantidad positiva
modules/pedidos/servicio.test.js	10	• codigoPedido da formato PED-000123 • acciones por estado • pedidoSchema valida cliente y líneas • pagosSchema exige al menos un pago con monto positivo • cobro solo en efectivo: se cobra el total redondeado y el ajuste queda registrado • el efectivo informado debe ser exactamente el redondeado • con tarjeta no hay redondeo y debe calzar exacto • pago mixto: el redondeo se aplica solo a lo que se paga en efectivo • un saldo en efectivo que se redondea a cero, o ya cubierto por otros medios, se rechaza • varias líneas en efectivo se redondean juntas
modules/pos/esquemas.test.js	3	• apertura exige caja y efectivo inicial no negativo • cierre exige el efectivo contado • venta exige líneas y pagos; el cliente es opcional
modules/proveedores/rut.test.js	2	• normaliza RUT válido • rechaza dígito verificador incorrecto o formato inválido



4. Pruebas de integración

4.1 Base de datos (automatizada)

El job **esquema** de la CI levanta PostgreSQL 16, instala *db/instalacion_completa.sql* (esquema base + migraciones 001-010) y vuelve a ejecutar todas las migraciones para comprobar que son **idempotentes**. Si una migración falla, no se publican imágenes ni se despliega.

Evidencia: CI_esquema_20261020.png (ejecución n.º 18) y ESQ-01_20261017.png (réplica local: instalación completa sin errores, diez migraciones idempotentes y 39 tablas con RLS).

4.2 API de punta a punta

El script *scripts/humo_y_seguridad.sh* ejecuta contra cualquier entorno los casos CP-INT y CP-SEG automatizables. Uso:

```
bash scripts/humo_y_seguridad.sh http://localhost:3000                    # local
ADMIN_CORREO=... ADMIN_CLAVE=... VEND_CORREO=... VEND_CLAVE=... \
bash scripts/humo_y_seguridad.sh https://farmaclick-medifarm.duckdns.org  # producción
```

ID	Caso	Esperado	Resultado	Evidencia
CP-INT-01	GET /api/health	200 { ok: true }	**Aprobado**	CP-INT-01a08_SEG-01a09_*_20261020.png
CP-INT-02	GET /api/health/db (consulta a la base)	200	**Aprobado**	CP-INT-01a08_SEG-01a09_*_20261020.png
CP-INT-03	Login del Administrador	200 con access_token, refresh_token y permisos	**Aprobado**	CP-INT-01a08_SEG-01a09_*_20261020.png
CP-INT-04	GET /api/auth/me con token	200 con rol y permisos	**Aprobado**	CP-INT-01a08_SEG-01a09_*_20261020.png
CP-INT-05..07	Stock, dashboard y usuarios como Administrador	200	**Aprobado**	CP-INT-01a08_SEG-01a09_*_20261020.png
CP-INT-08	Turno de caja como Vendedor	200 (turno o null)	**Aprobado**	CP-INT-01a08_SEG-01a09_*_20261020.png
CP-INT-09	Flujo completo en dev: crear OC > emitir > recibir > vender en caja > devolver > cerrar turno > revisar	Estados, stock y kardex coherentes en cada paso (manual, con capturas)	**Aprobado**	CP-INT-09_20261017_*.png (7 capturas)

Resultados de las ejecuciones:

El 20-10-2026, local, 17 aprobadas y 2 informativas (en local no hay Nginx); dev, 19 de 19; producción, 19 de 19. La primera ejecución en dev (16 aprobadas y 3 informativas) detectó las cabeceras de seguridad ausentes (CP-SEG-09); se corrigió nginx.conf, se desplegó y la segunda ejecución pasó 19 de 19.

Salidas: humo_dev_antes_20261020.txt, humo_dev.txt y humo_prod.txt. El 17-10-2026 la réplica local de la rama dev dio el mismo resultado: 17 aprobadas y 2 informativas por la API y 19 de 19 a través de Nginx con nginx.conf corregido (HUMO-API_20261017.png y HUMO-NGINX_20261017.png). CP-INT-09 es manual: Se ejecutó el 17-10-2026 sobre la réplica local de la rama dev y sus 7 capturas (CP-INT-09_20261017_1_oc_emitida.png a _7_kardex.png) muestran estados, stock y kardex coherentes en cada paso; Debería repetirse en dev antes de la aceptación con MediFarm (HU-83).

5. Pruebas funcionales y de aceptación

Cada caso se ejecuta en el entorno dev. En la columna **Resultado** se anota Aprobado/Fallido y en **Evidencia** el nombre del archivo de la captura (formato *CP-XXX-NN_AAAAMMDD.png*). Las ejecuciones registradas en esta versión son las del 17-10-2026, hechas sobre una réplica local de la rama dev; sus capturas están en el Anexo B (FarmaClick_08_Anexo_B_Evidencias_Funcionales_1.3.docx) y los archivos PDF y Excel, en la carpeta documentos/.

ID	HU	Caso	Resultado esperado	Resultado	Evidencia
CP-ACC-01	HU-03	Login con credenciales válidas	Entra y ve su nombre, rol y menú según permisos	**Aprobado**	CP-ACC-01_20261017_*.png (2 capturas)
CP-ACC-02	HU-03	Login con usuario desactivado	403 "Su cuenta no está habilitada"	**Aprobado**	CP-ACC-02_20261017.png
CP-ACC-03	HU-04	Quitar un permiso al rol y recargar	El módulo desaparece del menú y la API responde 403	**Aprobado**	CP-ACC-03_20261017_*.png (4 capturas)
CP-USR-01	HU-06	Crear usuario con correo repetido	Mensaje claro; no se crea	**Aprobado**	CP-USR-01_20261017_*.png (2 capturas)
CP-USR-02	HU-07	Editar la matriz de permisos	Cambio aplicado en la siguiente acción del usuario	**Aprobado**	CP-USR-02_20261017_*.png (3 capturas)
CP-CAT-01	HU-09	Proveedor con RUT con dígito verificador incorrecto	Rechazado	**Aprobado**	CP-CAT-01_20261017.png
CP-CAT-02	HU-10	Crear producto con costo 1000 y margen 0,35	Precio calculado por la base; SKU único	**Aprobado**	CP-CAT-02_20261017_*.png (3 capturas)
CP-CAT-03	HU-11	Marcar dos proveedores principales	Rechazado (solo uno)	**Aprobado**	CP-CAT-03_20261017_*.png (2 capturas)
CP-OC-01	HU-13	Crear OC en borrador y editarla	Número OC-000NNN; solo editable en Borrador	**Aprobado**	CP-OC-01_20261017_*.png (4 capturas)
CP-OC-02	HU-15	Recibir parcialmente una OC	Estado Recibida parcial; lotes y kardex "Recepción OC"; PMP actualizado	**Aprobado**	CP-OC-02_20261017_*.png (4 capturas)
CP-OC-03	HU-16	Descargar PDF de una OC recibida	PDF con logo, líneas, lo recibido y sello	**Aprobado**	CP-OC-03_20261017.png PDF en documentos/
CP-INV-01	HU-17	Definir stock mínimo y bajar el stock	El producto aparece destacado y en el informe "Stock bajo el mínimo"	**Aprobado**	CP-INV-01_20261017_*.png (2 capturas)
CP-INV-02	HU-18	Dar de baja un lote vencido	Movimiento "Producto vencido"; stock descontado	**Aprobado**	CP-INV-02_20261017_*.png (3 capturas)
CP-INV-03	HU-19	Intentar modificar el kardex (SQL en dev)	Error del trigger: el kardex es inmutable	**Aprobado**	CP-INV-03_20261017.png
CP-INV-04	HU-20	Ajuste negativo sin motivo	Rechazado (motivo obligatorio)	**Aprobado**	CP-INV-04_20261017_*.png (2 capturas)
CP-PED-01	HU-22	Reservar un pedido con más unidades que el stock	409 con explicación	**Aprobado**	CP-PED-01_20261017_*.png (2 capturas)
CP-PED-02	HU-22	Dejar un pedido sin pagar 20 minutos	Pasa a Expirado y libera el stock	**Aprobado**	CP-PED-02_20261017_*.png (3 capturas)

ID	HU	Caso	Resultado esperado	Resultado	Evidencia
CP-PED-03	HU-24	Cancelar un pedido Pagado	Stock devuelto y pagos anulados	**Aprobado**	CP-PED-03_20261017_*.png (2 capturas)
CP-POS-01	HU-27	Abrir dos turnos en la misma caja	Rechazado	**Aprobado**	CP-POS-01_20261017_*.png (3 capturas)
CP-POS-02	HU-28	Venta con efectivo $12.345	Cobro de $12.350 (Ley 20.956); redondeo +5 registrado	**Aprobado**	CP-POS-02_20261017_*.png (2 capturas)
CP-POS-03	HU-28	Venta con pago mixto (débito + efectivo)	Solo el efectivo se redondea; vuelto correcto	**Aprobado**	CP-POS-03_20261017_*.png (2 capturas)
CP-POS-04	HU-30	Enviar el comprobante por correo	Correo recibido con el PDF (SMTP configurado)	**Aprobado**	CP-POS-04_20261017_*.png (3 capturas)
CP-DEV-01	HU-34	Buscar pedidos que se pueden devolver por cliente y fechas	Solo pedidos Entregados dentro de 30 días	**Aprobado**	CP-DEV-01_20261017.png
CP-DEV-02	HU-32	Devolver una línea con descuento	Reembolso prorrateado por el medio original	**Aprobado**	CP-DEV-02_20261017_*.png (2 capturas)
CP-DEV-03	HU-33	Devolución en efectivo sin turno abierto	409 "abrir un turno"	**Aprobado**	CP-DEV-03_20261017.png
CP-DSH-01	HU-45	Dashboard de un mes con devoluciones	Ventas netas = ventas - devoluciones	**Aprobado**	CP-DSH-01_20261017.png
CP-DSH-02	HU-46	Exportar "Inventario valorizado" a Excel y PDF	Archivos con totales y logo (PDF)	**Aprobado**	CP-DSH-02_20261017_*.png (3 capturas) Excel + PDF en documentos/

5.1 Plan de pruebas de la caja (HU-55)

Se ejecuta en dev con dos usuarios de distinto rol. **Para simular el cierre automático** sin esperar a las 23:59: en el SQL Editor de Supabase dev, adelantar la *`fecha_apertura`* de un turno abierto al día anterior y ejecutar *`SELECT fn_cierre_automatico_turnos();`*. *Evidencias del 17-10-2026 (réplica local): Anexo B, sección 10.*

ID	Caso	Resultado esperado	Resultado	Evidencia
CP-CAJ-01	Cierre normal ciego por el cajero	Esperado y diferencia calculados; turno Cerrado	**Aprobado**	CP-CAJ-01_20261017_*.png (2 capturas)
CP-CAJ-02	Otro usuario intenta cerrar el turno ajeno	Rechazado (solo cierra quien abrió)	**Aprobado**	CP-CAJ-02_20261017.png
CP-CAJ-03	Cierre automático (simulado)	cierre_tipo "automatico", contado NULL, pendiente de arqueo	**Aprobado**	CP-CAJ-03_20261017_*.png (2 capturas)
CP-CAJ-04	Farmacia de turno marcada y cierre automático	Su turno NO se cierra	**Aprobado**	CP-CAJ-04_20261017_*.png (3 capturas)
CP-CAJ-05	Jefe de local cierra por fuerza mayor un turno de otro cajero	Exige motivo; turno Cerrado con cierre_tipo "forzado"	**Aprobado**	CP-CAJ-05_20261017_*.png (3 capturas)
CP-CAJ-06	Jefe de local de otra sucursal intenta el cierre forzado	Rechazado	**Aprobado**	CP-CAJ-06_20261017_*.png (2 capturas)
CP-CAJ-07	Registrar arqueo de un turno pendiente	Contado registrado; arqueo_por y arqueo_fecha	**Aprobado**	CP-CAJ-07_20261017_*.png (2 capturas)
CP-CAJ-08	Revisar un turno con arqueo pendiente	Rechazado	**Aprobado**	CP-CAJ-08_20261017.png CP-CAJ-03_20261017_b_pendiente_arqueo.png
CP-CAJ-09	Administrador corrige el monto de cierre con motivo de 5 caracteres	Rechazado (mínimo 10)	**Aprobado**	CP-CAJ-09_20261017.png
CP-CAJ-10	Administrador corrige con motivo válido antes de revisar	Esperado recalculado; registro inmutable en el historial	**Aprobado**	CP-CAJ-10_20261017_*.png (3 capturas)
CP-CAJ-11	Jefe de local intenta corregir montos	Rechazado (solo Administrador)	**Aprobado**	CP-CAJ-11_20261017_*.png (2 capturas)
CP-CAJ-12	Cajero intenta revisar su propio turno	Rechazado (revisión cruzada)	**Aprobado**	CP-CAJ-12_20261017_*.png (2 capturas)
CP-CAJ-13	Administrador revisa su propio turno	Permitido	**Aprobado**	CP-CAJ-13_20261017.png
CP-CAJ-14	Agregar observación y luego intentar editarla (SQL dev)	Se agrega; la edición falla (inmutable)	**Aprobado**	CP-CAJ-14_20261017_*.png (2 capturas)
CP-CAJ-15	Recordatorios 60 y 30 min antes (SMTP configurado)	Un correo de cada tipo, sin repetir (turno_aviso)	**Aprobado**	CP-CAJ-15_20261017_*.png (3 capturas)
CP-CAJ-16	Banner en el POS los últimos 60 minutos	Banner visible	**Aprobado**	CP-CAJ-16_20261017_*.png (3 capturas)
CP-CAJ-17	Cierre Z en PDF y Excel con hoja Historial	Documentos con la línea de tiempo completa	**Aprobado**	CP-CAJ-17_20261017_*.png (2 capturas) Excel + PDF en documentos/

5.2 Casos de la tienda en línea (Sprints 5 a 7, pendientes al 21-10-2026)

Se ejecutan en dev a medida que cada historia se termina. Los pagos se prueban con las tarjetas de prueba que publica Transbank.

ID	HU	Caso	Resultado esperado	Resultado	Evidencia
CP-WEB-01	HU-65	Llamar a /api/tienda/productos sin token	200 sin costos ni márgenes en la respuesta	**No ejecutado**	-
CP-WEB-02	HU-65	Cliente con sesión llama a un módulo del personal (/api/inventario)	403	**No ejecutado**	-
CP-WEB-03	HU-66	Buscar por nombre y filtrar por categoría	Solo productos activos con stock; precio con IVA	**No ejecutado**	-
CP-WEB-04	HU-67	Abrir la ficha de un producto sin stock	Se muestra agotado; no se puede agregar	**No ejecutado**	-
CP-WEB-05	HU-68	Registrarse con un RUT inválido	Rechazado con mensaje claro	**No ejecutado**	-
CP-WEB-06	HU-70	Agregar más unidades que el stock disponible	Rechazado; el carrito queda en el máximo disponible	**No ejecutado**	-
CP-WEB-07	HU-70	Modificar el precio en el navegador antes de confirmar	El servidor recalcula; el total no cambia	**No ejecutado**	-
CP-WEB-08	HU-71	Confirmar compra con retiro en tienda	Pedido canal web en "Pago pendiente" con reserva FEFO	**No ejecutado**	-
CP-WEB-09	HU-72	Pagar con tarjeta de prueba aprobada	transaccion_pago autorizada; pedido "Pagado"	**No ejecutado**	-
CP-WEB-10	HU-72	Recargar la página de retorno de Webpay	No se duplica el pago ni el cambio de estado	**No ejecutado**	-
CP-WEB-11	HU-73	Pago rechazado o anulado por el cliente	Transacción registrada; opción de reintentar	**No ejecutado**	-
CP-WEB-12	HU-71	No pagar en 20 minutos	Pedido "Expirado" y stock liberado	**No ejecutado**	-
CP-WEB-13	HU-77	Entregar un retiro con RUT distinto	Rechazado; el pedido sigue "Listo para retiro"	**No ejecutado**	-
CP-WEB-14	HU-78	Despacho a una comuna con costo configurado	Costo sumado al total y al monto de Webpay	**No ejecutado**	-
CP-WEB-15	HU-75	Un cliente intenta ver el pedido de otro	403 o 404	**No ejecutado**	-

6. Pruebas de rendimiento (HU-57)

Objetivo: verificar que la VM gratuita (1 OCPU, 1 GB) atiende la carga esperada de la farmacia (hasta 20 usuarios simultáneos, muy por sobre el uso real de un local).

Parámetro	Valor
Herramienta	k6 en Docker (*grafana/k6)*
Script	scripts/carga_k6.js
Escenario	Subida a 10 usuarios (30 s), 20 usuarios durante 1 min, bajada (30 s); cada iteración consulta salud de la base, stock, búsqueda de productos y dashboard
Criterios de aceptación	p95 de http_req_duration < 800 ms - tasa de errores < 1%
Entorno	Dev y producción (esta última fuera del horario de atención)
Realizada	20 de octubre de 2026 (línea base del Sprint 5, sin la tienda), en dev y en producción; producción a través del balanceador y por HTTPS
Ejecución	docker run --rm -i -e URL=... -e CORREO=... -e CLAVE=... grafana/k6 run - < scripts/carga_k6.js

Métrica	Meta	Dev	Producción	¿Cumple?
http_req_duration p(95)	< 800 ms	705,35 ms	744,51 ms	**Sí**
http_req_duration promedio	-	300,41 ms	311,54 ms	**-**
http_req_failed	< 1%	0,00 % (0 de 3.589)	0,00 % (0 de 3.553)	**Sí**
Iteraciones por segundo	-	7,29 (29,16 solicitudes/s)	7,25 (29,00 solicitudes/s)	**-**
CPU / memoria de la VM (docker stats)	< 80%	API: CPU máx. 8,16 %; memoria 88,29 MiB (9,25 %); VM: 498 de 954 MiB (52 %)	API: CPU máx. 13,51 %; memoria 85,46 MiB (8,96 %); VM: 493 de 954 MiB (52 %)	**Sí**

Resultado:

Con 20 usuarios simultáneos la VM de dev y la de producción responden con p(95) bajo 800 ms y sin errores; CPU y memoria quedan muy por debajo del 80 %.

Evidencia:

HU57_k6_resumen_docker_stats_dev_20261020.png, HU-57_k6_resumen_prod_20261020.png, HU-57_docker_stats_prod_20261020.png, k6_dev.txt y k6_prod.txt.

Referencia local:

El 17-10-2026, con 20 usuarios durante 2 minutos sobre la réplica local, p(95) de 15,04 ms, 5.317 solicitudes y 0,00 % de errores; es solo referencial y no sustituye la medición en la VM de 1 OCPU y 1 GB (HU-57_K6_20261017_LOCAL.png).

7. Pruebas de seguridad (HU-58)

ID	Prueba	Cómo	Esperado
CP-SEG-01	Credenciales inválidas	humo_y_seguridad.sh	401 sin revelar el dato incorrecto
CP-SEG-02	Validación de entrada	humo_y_seguridad.sh	400 Datos inválidos
CP-SEG-03/04	Sin token o token falso	humo_y_seguridad.sh	401
CP-SEG-05/06	Autorización por rol (Vendedor > usuarios, ajustes)	humo_y_seguridad.sh	403
CP-SEG-07	Inyección SQL en búsquedas	humo_y_seguridad.sh	Respuesta normal; consultas parametrizadas
CP-SEG-08	Identificador malformado	humo_y_seguridad.sh	400
CP-SEG-09	Cabeceras de seguridad en Nginx	humo_y_seguridad.sh contra dev/prod	nosniff, DENY, Referrer-Policy
CP-SEG-10	Fuerza bruta en el login	21 intentos en 15 min desde la misma IP	429 "Demasiados intentos"
CP-SEG-11	Escaneo de vulnerabilidades web	docker run -t ghcr.io/zaproxy/zaproxy:stable zap-baseline.py -t https://farmaclick-medifarm.duckdns.org	Sin alertas de riesgo alto
CP-SEG-12	Dependencias vulnerables	docker compose exec api npm audit --omit=dev	Sin vulnerabilidades críticas
CP-SEG-13	RLS y privilegios de la base	scripts/seguridad_rls.sql en el SQL Editor	RLS en las 39 tablas; anon/authenticated sin privilegios
CP-SEG-14	Secretos en el repositorio	Job seguridad de la CI en cada push	Pipeline detenido si hay .env, _privado/ o credenciales
CP-SEG-15	HTTPS y certificado	Navegador / ssllabs.com	Certificado válido; solo puerto 443 abierto en producción
CP-SEG-16	Exposición de la VM de producción	curl http://155.181.171.118	Sin respuesta (NSG solo permite el balanceador)

Resultados de la línea base (20 y 21 de octubre de 2026, Sprint 5)

ID	Resultado	Detalle	Evidencia
CP-SEG-01	**Aprobado**	HTTP 401 con clave incorrecta, sin revelar qué dato falló.	humo_dev.txt y humo_prod.txt; CP-INT-01a08_SEG-01a09_{dev,prod}_20261020.png; HUMO-API_20261017.png y HUMO-NGINX_20261017.png (réplica local)
CP-SEG-02	**Aprobado**	HTTP 400 con correo inválido (validación zod).	Ídem
CP-SEG-03/04	**Aprobado**	HTTP 401 sin token y con token falso.	Ídem
CP-SEG-05/06	**Aprobado**	HTTP 403: el Vendedor no accede a usuarios ni a la escritura de inventario.	Ídem
CP-SEG-07	**Aprobado**	La búsqueda con inyección SQL no rompe la API (HTTP 200); en la réplica local la tabla producto sigue existiendo con sus 90 productos.	Ídem; CP-SEG-07_20261017.png (réplica local)
CP-SEG-08	**Aprobado**	Identificador malformado: HTTP 400.	Ídem
CP-SEG-09	**Aprobado**	Hallazgo corregido: el 17-10-2026 se reprodujo en la réplica local con Nginx (cabeceras ausentes en /, /login y /assets/) y el 20-10-2026 se confirmó en dev (primera ejecución: 16 aprobadas, 3 informativas); tras corregir nginx.conf y desplegar, 19 de 19 en dev y en producción.	humo_dev_antes_20261020.txt, humo_dev.txt, humo_prod.txt; CP-INT-01a08_SEG-01a09_dev_antes_20261020.png; CP-SEG-09_20261017_DEFECTO.png
CP-SEG-10	**Aprobado**	Intentos 1 a 20 con HTTP 401 y el 21 con HTTP 429 "Demasiados intentos" (dev); mismo resultado en la réplica local.	CP-SEG-10_20261021.png; CP-SEG-10_20261017.png (réplica local)

ID	Resultado	Detalle	Evidencia
CP-SEG-11	**Aprobado**	ZAP 2.17.0: 0 alertas de riesgo alto, 1 media (CSP no definida), 5 bajas (HSTS, Permissions-Policy, COEP, COOP y CORP) y 5 informativas.	CP-SEG-11_20261020_1.png a _3.png; CP-SEG-11_20261020_reporte.html
CP-SEG-12	**Aprobado con observación**	Backend: 2 vulnerabilidades moderadas (uuid < 11.1.1 a través de exceljs), 0 críticas ni altas; exceljs solo usa uuid v4 sin buffer, por lo que el aviso no se explota. Frontend: 0.	CP-SEG-12_20261020.png y _2.png; npm_audit_api_20261020.txt; npm_audit_web_20261020.txt; CP-SEG-12_20261017.png (réplica local)
CP-SEG-13	**Aprobado**	Dev y producción: 0 tablas sin RLS, 0 privilegios para anon y authenticated, 39 tablas con la política p_backend_all y 3 tareas programadas activas.	CP-SEG-13_20261020_{dev,prod}_{1,2,3,5}.png; CP-SEG-13_20261017_LOCAL.png (réplica local, consultas 1 a 3)
CP-SEG-14	**Aprobado**	Ejecución n.º 18 con el repositorio limpio: job seguridad en verde. Prueba negativa (Pull Request con credencial_prueba.txt): job seguridad en rojo (ejecución n.º 19), desplegar e imágenes omitidos; Pull Request cerrado sin fusionar.	CP-SEG-14_20261020_1.png y CP-SEG-14_20261021_2a a 2g (.png); CP-SEG-14_20261017.png (réplica local del job)
CP-SEG-15	**Aprobado**	Certificado de Let's Encrypt válido del 13-10-2026 al 11-01-2027; SSL Labs: A- (solo TLS 1.2); solo el puerto 443 responde.	CP-SEG-15_20261020_1a a 3 (16 capturas .png)
CP-SEG-16	**Aprobado**	La IP de la VM de producción no responde por el puerto 80 (tiempo agotado a los 10 s); el grupo de seguridad solo permite TCP 80 desde 10.0.0.0/16.	CP-SEG-16_20261020_1.png y _2.png

Observaciones y riesgos conocidos

- **Cabeceras sin definir:** el balanceador y Nginx no envían Content-Security-Policy, Strict-Transport-Security, Permissions-Policy ni las políticas de aislamiento (COOP, COEP, CORP). No hay alertas de riesgo alto; se propone incorporarlas como mejora.
- **HTTPS:** el puerto 80 del balanceador está cerrado (no hay redirección de http a https) y solo se admite TLS 1.2.
- **Certificado:** vence el 11-01-2027 y se renueva manualmente; renovarlo antes del 15-12-2026.
- **SSH:** el puerto 22 de las VM acepta conexiones desde Internet porque el despliegue de la CI se conecta por SSH; el acceso es solo con llave. Evaluar restringirlo por origen.
- **Sistema operativo:** las dos VM tienen actualizaciones y reinicio pendientes (dev: 10 actualizaciones; producción: 15, de ellas 4 de seguridad). Aplicarlas en una ventana fuera de horario y repetir la prueba de humo.
- **exceljs:** reevaluar el aviso de uuid al actualizar exceljs.

8. Evidencias

- Capturas guardadas en `Fase 2/Evidencias Proyecto/Evidencias de sistema/Pruebas/` con el nombre `CP-XXX-NN_AAAAMMDD.png`.
- Para las automatizadas: Se capturó del job en GitHub Actions (con número de ejecución) y de la salida del script.
- Para k6: Resumen de consola y la captura de `docker stats` de la VM durante la prueba.
- Para ZAP: Reporte adjunto HTML (-r reporte_zap.html), guardado como CP-SEG-11_AAAAMMDD_reporte.html.
- Las capturas de integración, seguridad y rendimiento de este documento están reunidas, con el nombre de cada archivo bajo cada captura, en el Anexo A (FarmaClick_08_Anexo_A_Evidencias_Tecnicas_1.3.docx); las de las pruebas funcionales y del flujo CP-INT-09, en el Anexo B (FarmaClick_08_Anexo_B_Evidencias_Funcionales_1.3.docx).
- Salidas de texto y reportes con su nombre: humo_dev_antes_20261020.txt, humo_dev.txt, humo_prod.txt, k6_dev.txt, k6_prod.txt, npm_audit_api_20261020.txt, npm_audit_web_20261020.txt, CP-SEG-11_20261020_reporte.html y CP-SEG-11_20261020_reporte.json.
- Archivos generados por la aplicación, en la carpeta documentos/: OC-000001.pdf, PED-000005.pdf, CierreZ_Caja1.pdf, CierreZ_Caja1-2026-10-18.xlsx, inventario-valorizado.pdf e inventario-valorizado.xlsx.
- Cuando un caso tiene varias capturas, el nombre lleva un sufijo con el paso (_1, _2, ... o _a, _b, ...) o con el entorno (_dev, _prod, _LOCAL).

9. Resumen por sprint

Sprint	Pruebas realizadas	Resultado
Sprint 1	Unitarias de SQL helpers y RUT; esquema base en PostgreSQL local	Aprobadas
Sprint 2	Unitarias de ajustes; recepción de OC y kardex probados en local	Aprobadas
Sprint 3	Unitarias de pedidos, cobro y redondeo, devoluciones, cuadratura, dashboard	Aprobadas
Sprint 4	CI completa en cada push (61 unitarias + esquema + build); prueba de humo en producción con HTTPS	Aprobadas
Sprint 5	Plan de pruebas de caja (HU-55), 17 casos el 17-10. Línea base sobre el módulo administrativo: integración CP-INT (17 y 20-10), seguridad CP-SEG (20 y 21-10) y rendimiento con k6 (20-10). Casos CP-WEB de catálogo, cuenta y carrito.	HU-55 aprobada; línea base aprobada, con las observaciones de seguridad de la sección 7; CP-WEB planificados
Sprint 6	Integración de la API con base real sumando el checkout, con lo que se cierra HU-56; casos CP-WEB de checkout y Webpay Plus.	Planificadas
Sprint 7	Punta a punta de la compra web (HU-82); seguridad repetida con la tienda publicada: rol Cliente, endpoints públicos y ZAP, con lo que se cierra HU-58.	Planificadas
Sprint 8	Aceptación con MediFarm (HU-83); k6 con el catálogo público incluido, con lo que se cierra HU-57; prueba de humo de la versión v1.0.	Planificadas